Oral Presentation Guide & Discursive Speaker Script

Complete walk-through, slide by slide, for the final project defense: *Protecting Health Data: k-Anonymity vs Differential Privacy under GDPR and NIS2*

Institution: ISCTE – Instituto Universitário de Lisboa (ISTA)
Course: Data Privacy (Privacidade de Dados) – 2025/2026
Professor: Valderi Leithardt

Students / Speakers:
• Mattia Malservigi (145863)
• Matteo Calloni (145860)
• Manuel Mulloni (145866)

How to use this guide during the presentation: This document contains the exact discursive speech notes corresponding to each of the 15 slides of the presentation. For every slide, you have the visual context (what is shown on screen), the key conceptual takeaways, and a ready-to-read, natural English narrative ('What to say during exposure'). The estimated total presentation time is approximately 15 to 18 minutes (about 1 minute per slide).

Slide 1 — Title & Institutional Cover

Visual Elements on Screen:

Navy blue title banner, ISCTE logo, course details, professor name, and group members with student numbers.

Slide Content (Bullet Points for Presentation):

- Protecting Health Data: k-Anonymity vs Differential Privacy under GDPR and NIS2
- A theoretical study and practical test with a Python prototype
- Group Final Project: Mattia Malservigi, Matteo Calloni, Manuel Mulloni
- Course: Data Privacy – Professor: Valderi Leithardt (ISCTE-IUL, 2025/2026)

Discursive Speaking Script (What to say during exposure):

"Good morning Professor Leithardt and colleagues. Today, our group—composed of Mattia Malservigi, Matteo Calloni, and Manuel Mulloni—is proud to present our final project for the Data Privacy course at ISCTE. Our work is titled: 'Protecting Health Data: k-Anonymity vs Differential Privacy under GDPR and NIS2: A theoretical study and a practical test with a Python prototype'. In this presentation, we explore how modern healthcare institutions can safely share electronic health records for scientific research while simultaneously satisfying the strict mandates of European data privacy law (the GDPR) and critical infrastructure cybersecurity obligations (the NIS2 Directive)."

Slide 2 — Clinical Research vs. Patient Privacy

Visual Elements on Screen:

Two-column conceptual layout contrasting the research need for medical microdata with privacy attack vectors and project objectives.

Slide Content (Bullet Points for Presentation):

- Secondary use of EHR: Vital for disease epidemiology, treatment evaluation, and clinical AI.
- High sensitivity under GDPR Art. 9: Leaks lead to stigmatization, insurance bias, and discrimination.
- Sweeney's Re-identification Paradox: Removing direct IDs is insufficient; 87% unique by ZIP, Gender, Birthdate.
- Project Objectives: Rigorous comparative evaluation, real-world Privacy Gateway architecture, and full reproducibility.

Discursive Speaking Script (What to say during exposure):

"To introduce our motivation: modern medical breakthroughs rely heavily on the secondary use of electronic health records. However, health data represents a special category under GDPR Article 9 because of its acute sensitivity. A naive approach to privacy—simply scrubbing patient names and fiscal codes—has been proven completely flawed since Sweeney's landmark study, which demonstrated that 87% of individuals can be re-identified using only three quasi-identifiers: postal code, gender, and date of birth. Therefore, our project objective was not merely to write code, but to engineer an end-to-end, reproducible Privacy Gateway that intercepts queries, strictly mediates access, and compares the fundamental trade-offs between syntactic anonymization and mathematical Differential Privacy."

Slide 3 — Regulatory Interplay: GDPR and NIS2 Directive

Visual Elements on Screen:

Comparative cards detailing the specific articles and convergent incident handling mechanisms between GDPR and NIS2.

Slide Content (Bullet Points for Presentation):

- GDPR (EU 2016/679): Focuses on the rights of natural persons (Art. 5 data minimization, Art. 9 special category).
- Recital 26 Legal Dichotomy: Pseudonymized data remains personal data; truly anonymous data is exempt from GDPR.
- NIS2 Directive (EU 2022/2555): Focuses on cybersecurity resilience of essential sectors (Healthcare in Annex I).
- Symbiotic Convergence: A breach into a hospital gateway triggers BOTH NIS2 Art. 23 (24h/72h) and GDPR Art. 33 (72h).

Discursive Speaking Script (What to say during exposure):

"A central pillar of our theoretical analysis is the interplay between GDPR and the NIS2 Directive. Historically, organizations treated data protection and cybersecurity as separate silos. However, in healthcare platforms, they are deeply symbiotic. Under GDPR Recital 26, pseudonymized data is still legally personal data, whereas anonymized data is exempt. Meanwhile, NIS2 Article 21 mandates specific technical measures: access control, cryptographic hygiene, and rapid incident response. If an attacker penetrates the research gateway, this event simultaneously constitutes a significant incident under NIS2 and a personal data breach under GDPR Article 33. Therefore, an effective platform must possess a unified, automated response capability capable of meeting the 24-hour NIS2 Early Warning and the 72-hour GDPR notification deadlines."

Slide 4 — Privacy Paradigms: Syntactic vs Mathematical Guarantees

Visual Elements on Screen:

Side-by-side comparison between k-anonymity (Mondrian table generalization) and Differential Privacy (Laplace query perturbation).

Slide Content (Bullet Points for Presentation):

- k-Anonymity: Ensures every combination of quasi-identifiers appears in >= k records; published once as static microdata.
- k-Anonymity Vulnerabilities: Subject to Homogeneity attacks (identical sensitive diagnoses) and background knowledge.
- Differential Privacy: Adds calibrated noise Laplace(Delta f / epsilon) to query responses; mathematical bound exp(epsilon).
- DP Trade-offs: Independent of attacker auxiliary knowledge, but limited by a finite privacy budget and poor small-cohort accuracy.

Discursive Speaking Script (What to say during exposure):

"Moving to the algorithmic foundations, we contrast two distinct privacy models. On the left, syntactic k-anonymity transforms quasi-identifiers into intervals—for example using the Mondrian algorithm—guaranteeing that every patient hides among at least k records. Its great advantage is that the anonymized table is published once, allowing researchers to explore unlimited hypotheses. Its weakness is susceptibility to homogeneity and linkage attacks. On the right, Differential Privacy provides a rigorous mathematical guarantee independent of adversary background knowledge. By injecting calibrated Laplace noise scaled to the query's global sensitivity, it bounds the probability that any individual can be distinguished. However, every question consumes a finite privacy budget epsilon, and as we will show, accuracy degrades severely on small patient sub-cohorts."

Slide 5 — Collaborative Platform & Synthetic Clinical Cohort

Visual Elements on Screen:

Architecture diagram (Figure 1) alongside details of the synthetic cohort of 1,000 patients and 64 oncology cases.

Slide Content (Bullet Points for Presentation):

- Zero Direct Access Principle: Researchers never connect directly to the raw clinical database.
- Synthetic Cohort (N = 1,000): Realistic correlations between Age, BMI, and Blood Pressure under clinical baselines.
- Rare Oncology Sub-Cohort (N = 64): Dedicated subgroup representing 6.4% of the population to stress-test small-sample utility.
- Three Distinct Personas (Figure 5): Healthcare Worker (data entry), Privacy Officer (governance), Researcher (data consumer).

Discursive Speaking Script (What to say during exposure):

"In Section 3.2, we engineered the practical prototype. The operational scenario models an external research team studying metabolic and cardiovascular diseases. The core principle is 'Zero Direct Access': researchers never see raw data; everything is mediated by the Privacy Gateway. We generated a synthetic cohort of 1,000 adult patients with clinically validated correlations: blood pressure correlates with age and BMI, and patients with hypertension or cardiovascular diagnoses have elevated baselines. Crucially, we embedded an exact subpopulation of 64 oncology patients. This small cohort serves as an intentional benchmark to evaluate how both k-anonymity and Differential Privacy perform on rare disease groups."

Slide 6 — Privacy Gateway Enforcement Rules (Table 8)

Visual Elements on Screen:

Structured grid presenting Rules R1 through R8, mapping technical enforcement mechanisms to NIS2 and GDPR articles.

Slide Content (Bullet Points for Presentation):

- R1 & R2 (Auth & Revocation): Bearer tokens validated against identity registry; revoked tokens return HTTP 403.
- R3 (Budget Manager): Sequential composition tracker ensuring requested epsilon <= remaining budget.
- R4 (Abuse Detection): Rate limit (<= 10 qpm) and fingerprint scanner for reconstruction attempts; triggers auto-revocation.
- R5 & R6 (Cell & Attribute Protection): Suppresses queries on cohorts < 5 records; raw clinical data strictly forbidden.
- R7 & R8 (Chaining & Reporting): SHA-256 hash-chain audit log; automated JSON dossier generation for NIS2 Art. 23 and GDPR Art. 33.

Discursive Speaking Script (What to say during exposure):

"To enforce compliance systematically, the Gateway implements the eight rules summarized in Table 8. Rules 1 and 2 handle cryptographic token authentication and immediate revocation. Rule 3 tracks privacy budget depletion under sequential composition. Rule 4 is our automated abuse detection engine: it detects rapid overlapping queries designed to isolate a single patient via differencing, and immediately trips a circuit breaker that revokes the researcher's token. Rule 5 suppresses small cells under 5 records. Finally, Rules 7 and 8 provide the cryptographic backbone: every single gateway event is committed to a tamper-evident SHA-256 hash chain, and any security anomaly instantly triggers the generation of regulator-ready JSON incident dossiers for CNCS and CNPD."

Slide 7 — Prototype in Action: Scientific Researcher Interface

Visual Elements on Screen:

Live screenshot of the Web Dashboard (Scientific Access tab) showing budget bar at 4.00, noisy query output 143.29 mmHg, and baseline 138.56 mmHg.

Slide Content (Bullet Points for Presentation):

- Active Persona: Researcher Matteo Calloni (Cardio/Oncology Laboratory).
- Privacy Budget Bar: Real-time visual tracking of remaining epsilon (4.00 / 5.00 remaining, 1.00 spent across 2 queries).
- DP Query Execution: Bounded mean query on Systolic Blood Pressure for the Oncology Sub-Cohort (N = 64).
- Gateway Response: Noisy output 143.29 mmHg vs true baseline 138.56 mmHg; Laplace scale b = 3.75, MSE = 28.125 $mmHg^2$.
- Anonymized Microdata: One-click download of validated k-anonymized CSV datasets; abuse trigger button for testing.

Discursive Speaking Script (What to say during exposure):

"Here you see the actual running prototype from the researcher's perspective. In this screenshot, Researcher Matteo Calloni is authenticated with a privacy budget of 5.00 epsilon. The progress bar shows 4.00 remaining after executing two queries. Notice the query console: the researcher requested the mean systolic blood pressure specifically for the Oncology sub-cohort (N = 64). The Privacy Gateway calculated the global sensitivity, added Laplace noise with scale b = 3.75, and returned a noisy estimate of 143.29 mmHg, compared to the true value of 138.56 mmHg. The interface also provides transparent feedback on the theoretical MAE and MSE, and allows the researcher to download pre-approved k-anonymized microdata or test gateway security boundaries."

Slide 8 — Prototype in Action: Privacy Officer & Incident Management

Visual Elements on Screen:

Live screenshot of the Governance & NIS2 Compliance tab showing k=5 approval, tamper-evident audit table with ALERT status, and JSON incident report link.

Slide Content (Bullet Points for Presentation):

- Dataset Anonymization: Admin sets threshold k = 5, enters research justification, and triggers Mondrian generalization.
- Automated Attack Mitigation: Simulated reconstruction burst detected (Rule 4); token revoked instantly.
- Visual Audit Badges: Log entries #62 and #63 display red ALERT badges for REVOKE_TOKEN and SECURITY_INCIDENT.
- Regulatory Incident Dossier: Immediate generation of 'Attempted reconstruction attack' critical incident report.
- Direct Regulatory Export: One-click button to download machine-readable JSON notification dossiers.

Discursive Speaking Script (What to say during exposure):

"Switching to the Privacy Officer persona, this second screenshot demonstrates governance and incident automation in action. On the left, the administrator can configure the anonymity threshold—here set to k = 5—input a research justification, and approve the release of a GDPR-compliant dataset. On the right, observe what happened when an automated reconstruction attack was simulated: the Gateway detected the repeated queries, tripped the circuit breaker, and revoked the researcher's token. In the audit trail, events #62 and #63 appear in red as ALERT statuses. At the bottom right, you can see the generated regulatory incident dossier, complete with a button to download the structured JSON report for the authorities."

Slide 9 — Prototype in Action: Cryptographic Audit Logging (NIS2 Art. 21)

Visual Elements on Screen:

Live screenshot of the Tamper-Evident Audit Trail showing transaction indices #62 through #73, action badges, status pills, and SHA-256 hashes.

Slide Content (Bullet Points for Presentation):

- NIS2 Art. 21(2)(h) Operationalized: Non-repudiation and forensic auditability through immutable cryptographic chaining.
- Mathematical Linkage: Each entry computes H_i = SHA-256(H_{i-1} || index || timestamp || user || action || status).
- Granular Event Auditing: Tracks AUTHENTICATE, APPROVE_DATASET, EXECUTE_DP_QUERY, REJECTED, and SECURITY_INCIDENT.
- One-Click Integrity Verification: Algorithmic audit recalculates hashes from Genesis; zero tampering detected across all blocks.

Discursive Speaking Script (What to say during exposure):

"This third screenshot focuses on our cryptographic audit trail, which implements NIS2 Article 21(2)(h). Every single action—from authentication to DP execution and security rejections—is permanently committed to an append-only JSONL ledger. Each block contains the SHA-256 digest of the entire record concatenated with the hash of the preceding block. If an adversary or rogue administrator attempts to alter a historical query or backdate an entry, the hash chain is irreparably broken. Our built-in verification function audits the entire chain from the genesis block in milliseconds, providing mathematical proof of log integrity."

Slide 10 — DP Evaluation: The Small Cohort Dilemma (Table 12)

Visual Elements on Screen:

Complete Table 12 comparing noise scale b, empirical MAE, and empirical MSE between All Patients (N=1000) and Oncology (N=64) across epsilon values.

Slide Content (Bullet Points for Presentation):

- Monte Carlo Rigor: 1,000 repetitions per epsilon value on bounded systolic BP ([90, 210] mmHg).
- Global Sensitivity: All Patients (N = 1000) Delta f = 0.12 mmHg vs Oncology Group (N = 64) Delta f = 1.875 mmHg.
- Full Cohort Utility: At epsilon = 0.5, empirical MAE is only 0.23 mmHg (virtually imperceptible in clinical epidemiology).
- Small Cohort Utility Collapse: At epsilon = 0.5, Oncology MAE is 3.91 mmHg (MSE = 31.61 $mmHg^2$); at epsilon = 0.05, MAE escalates to 37.60 mmHg!
- Empirical Law: DP noise scales inversely with sample size (Delta f proportional to 1/N), creating severe barriers for rare disease research.

Discursive Speaking Script (What to say during exposure):

"Now we arrive at our quantitative benchmark results. Table 12 presents the error of the Laplace Differential Privacy mean across six epsilon values, evaluated through 1,000 Monte Carlo repetitions. For the full cohort of 1,000 patients, DP performs remarkably well: at epsilon = 0.5, the empirical MAE is only 0.23 mmHg, which easily preserves clinical utility. However, look at the right side of the table: for our oncology sub-cohort of 64 patients, global sensitivity is over 15 times larger. At epsilon = 0.5, the oncology error jumps to nearly 4 mmHg. Under strong privacy, epsilon = 0.05, the error explodes to 37.6 mmHg, with an MSE exceeding 2,800. This demonstrates a crucial finding: Differential Privacy introduces severe utility degradation for rare medical conditions because noise is fundamentally inversely proportional to sample size."

Slide 11 — k-Anonymity Evaluation: Information Loss vs Homogeneity (Table 13)

Visual Elements on Screen:

Complete Table 13 detailing equivalence class count, min size, average size, NCP, linkage risk, and homogeneity counts for k in {3, 5, 10, 20, 50}.

Slide Content (Bullet Points for Presentation):

- Multidimensional Mondrian: Applied across Age, Gender, Postal Area, and BMI for N = 1,000 patients.
- Failure of k = 3: While NCP loss is low (0.0720), 11 equivalence classes suffer from Homogeneity (l-diversity = 1, 100% attribute leak!).
- Optimal Operational Equilibrium (k = 5): Exactly zero homogeneous classes (min l-diversity = 2), low loss (NCP = 0.1138), and max risk bounded to 20%.
- High Generalization Distortion (k = 50): Linkage risk drops below 2%, but information loss triples (NCP = 0.3381) as intervals widen.
- Practical Recommendation: k = 5 provides the optimal baseline for microdata publishing in clinical research.

Discursive Speaking Script (What to say during exposure):

"Table 13 shows our evaluation of syntactic k-anonymity using the Mondrian algorithm across five threshold values. The most critical theoretical insight appears at k = 3: although information loss is minimal at 7.2%, exactly 11 equivalence classes suffer from the Homogeneity Attack. In those classes, every single patient has the exact same diagnosis, meaning an attacker achieves 100% attribute disclosure despite formal 3-anonymity! However, when we increase the threshold to k = 5, homogeneous classes drop to zero, minimum l-diversity reaches 2, and information loss remains remarkably low at 11.4%, with linkage risk strictly capped at 20%. Pushing k to 50 lowers linkage risk to 1.9%, but triples information loss to 33.8%. Therefore, k = 5 represents the optimal operational choice."

Slide 12 — Privacy-Utility Trade-off Curves (Figure 2)

Visual Elements on Screen:

Generated high-resolution Figure 2: (a) Log-log plot of DP MAE error vs epsilon; (b) Dual-axis Pareto curve of k-anonymity NCP loss vs maximum linkage risk.

Slide Content (Bullet Points for Presentation):

- Figure 2(a) - DP Error Scaling: Log-log curve proving empirical alignment with theoretical bounds (MAE = b); highlights constant 15.6x error offset for oncology.
- Figure 2(b) - k-Anonymity Trade-off: Pareto curve showing monotonically increasing Information Loss (green) against monotonically decreasing Linkage Risk (orange).
- Structural Trade-off: DP allows continuous mathematical tuning via epsilon; k-anonymity guarantees bounded linkage risk but requires l-diversity auditing.

Discursive Speaking Script (What to say during exposure):

"Figure 2 visually synthesizes these findings. In subplot (a), the log-log plot shows that empirical MAE perfectly tracks theoretical noise scale b. Notice the red dashed curve for oncology: it runs strictly parallel to the blue curve for all patients, but is offset by a factor of 15.6. In subplot (b), we see the classic Pareto frontier of k-anonymity: as k increases along the x-axis, the orange curve shows maximum linkage risk falling from 33% to under 2%, while the green curve shows information loss rising from 7% to nearly 34%. Together, these plots demonstrate the fundamental trade-off: in DP you control risk through noise injection; in k-anonymity you control risk through generalization intervals."

Slide 13 — Exploratory Research: DP Budget Decay vs Static Table (Figure 3)

Visual Elements on Screen:

Generated high-resolution Figure 3 comparing MAE of sequential range-count queries between Differential Privacy (budget decay) and k-anonymity (constant error).

Slide Content (Bullet Points for Presentation):

- Exploratory Research Simulation: Evaluating a sequence of Q in [1, 50] demographic range queries under fixed budget epsilon_total = 1.0.
- DP Sequential Budget Decay: Privacy budget is split (epsilon_i = 1.0 / Q); noise scale b = Q / 1.0 grows linearly!
- Linear DP Error Growth: Empirical MAE increases from 0.91 at Q = 1 to 24.42 at Q = 25 and 49.96 at Q = 50.
- k-Anonymity Constant Error: Generalized once upon release; researchers execute unlimited queries with constant error (MAE = 28.52).
- Strategic Rule: DP is optimal for targeted, finite statistical queries (Q <= 28); k-anonymity is essential for open hypothesis exploration.

Discursive Speaking Script (What to say during exposure):

"Figure 3 illustrates one of the most practical contributions of our study: what happens when researchers explore data over time? We simulated a sequence of 1 to 50 range queries under a fixed privacy budget of epsilon = 1.0. Under Differential Privacy, the sequential composition theorem requires splitting the budget across queries. As Q increases, each query receives less budget, causing the noise scale to expand linearly: DP error climbs from under 1 at Q = 1 to nearly 50 at Q = 50. In contrast, the blue dashed line represents the k-anonymized table (k = 5): because generalization occurs once during release, the researcher can run hundreds of exploratory queries with constant error. This establishes a clear decision rule: DP is ideal for answering a few predefined statistical queries; k-anonymity is necessary for open exploratory science."

Slide 14 — Incident Response Velocity: NIS2 Art. 23 & GDPR Art. 33 (Figure 4)

Visual Elements on Screen:

Generated Figure 4 timeline diagram showing the milestone steps: T0 Awareness, 24h Early Warning, 72h Notification (NIS2/GDPR), and 1-month Final Report.

Slide Content (Bullet Points for Presentation):

- Automated Bridge: Unifying technical SIEM rule triggers with legal reporting obligations.
- T = 00:00: Gateway Rule 4 detects 4 rapid identical range queries (reconstruction attack); trips circuit breaker and revokes token.
- T < 00:01: NIS2 Art. 23(4)(a) Early Warning dossier generated in JSON format for the CSIRT (CNCS) in less than one minute (< 24h deadline).
- T < 00:01: GDPR Art. 33 Personal Data Breach notification dossier generated for the DPA (CNPD) (< 72h deadline).

• Forensic Continuity: SHA-256 hash-chain audit log automatically preserves complete evidence for the 1-month Final Incident Report.

Discursive Speaking Script (What to say during exposure):

"Figure 4 illustrates our incident response timeline, demonstrating how the prototype operationalizes NIS2 Article 23 and GDPR Article 33. When an attacker attempts a reconstruction attack, the gateway detects the anomaly within four queries and revokes the token. Instead of relying on manual security reporting, the system instantly compiles two standardized JSON dossiers: a NIS2 Early Warning for the National Cybersecurity Centre (CNCS), generated within seconds—well ahead of the 24-hour statutory deadline—and a parallel GDPR Article 33 breach notification for the CNPD, fulfilling the 72-hour requirement. Because every transaction is recorded in the SHA-256 hash chain, forensic evidence is mathematically preserved for the final one-month report."

Slide 15 — Summary of Contributions & Future Outlook

Visual Elements on Screen:

Summary card with three core takeaways, future research bullet points, institutional closing banner, and ISCTE logo.

Slide Content (Bullet Points for Presentation):

• Core Takeaway 1: Data privacy and cybersecurity are indivisible; mathematical DP requires robust gateway access and audit controls (NIS2 Art. 21).

• Core Takeaway 2: k-Anonymity (k = 5) provides an optimal exploratory baseline; DP provides formal bounds but collapses on rare clinical cohorts.

• Core Takeaway 3: Automated compliance engines successfully reconcile aggressive reporting deadlines (< 24h / 72h) with technical infrastructure.

• Future Directions: Federated Learning with Local DP (PRISEC models), zk-SNARKs for budget verification, and hardware enclaves (TEEs).

• Acknowledgments: Professor Valderi Leithardt – ISCTE-IUL Data Privacy Course 2025/2026. Thank you for your attention!

Discursive Speaking Script (What to say during exposure):

"To conclude: our work demonstrates that privacy and cybersecurity cannot be separated. An organization deploying Differential Privacy is still non-compliant under European law if its gateway lacks the access control and tamper-evident auditing required by NIS2. Technically, k-anonymity at k = 5 provides an optimal, robust baseline for exploratory microdata, while Differential Privacy provides rigorous mathematical protection for predefined queries, despite limitations on small cohorts. Looking ahead, exciting extensions include integrating federated learning with local DP, using zero-knowledge proofs to audit privacy budgets, and deploying gateways inside hardware-enforced trusted execution environments. We thank Professor Leithardt for his guidance throughout the course, and we are now open to any questions. Thank you."